

Task 9: Bank App Vulnerability Report

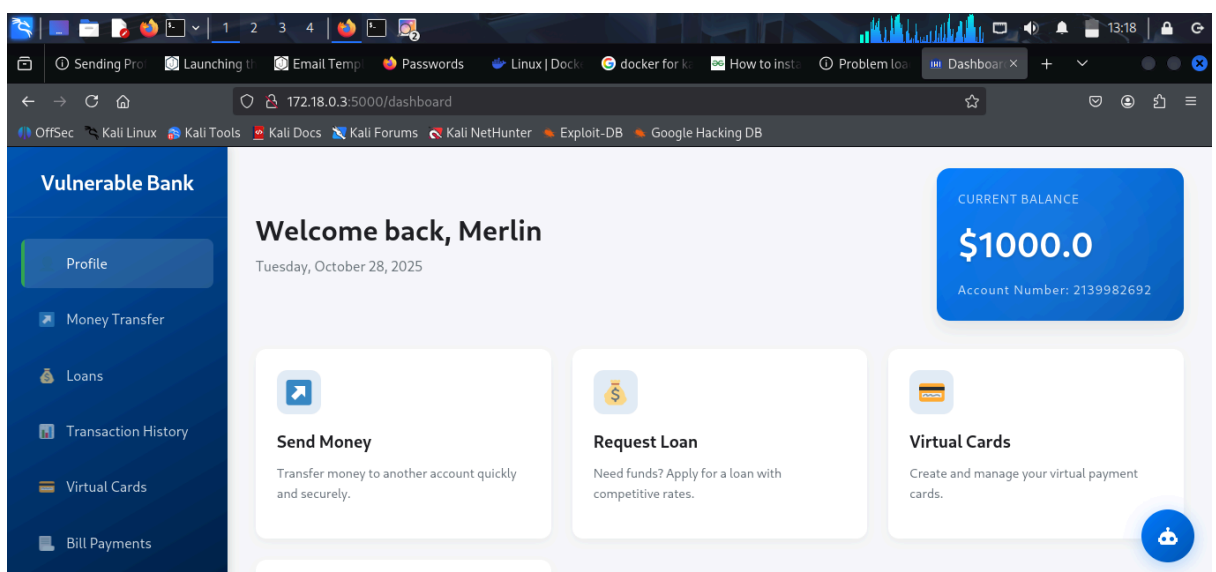
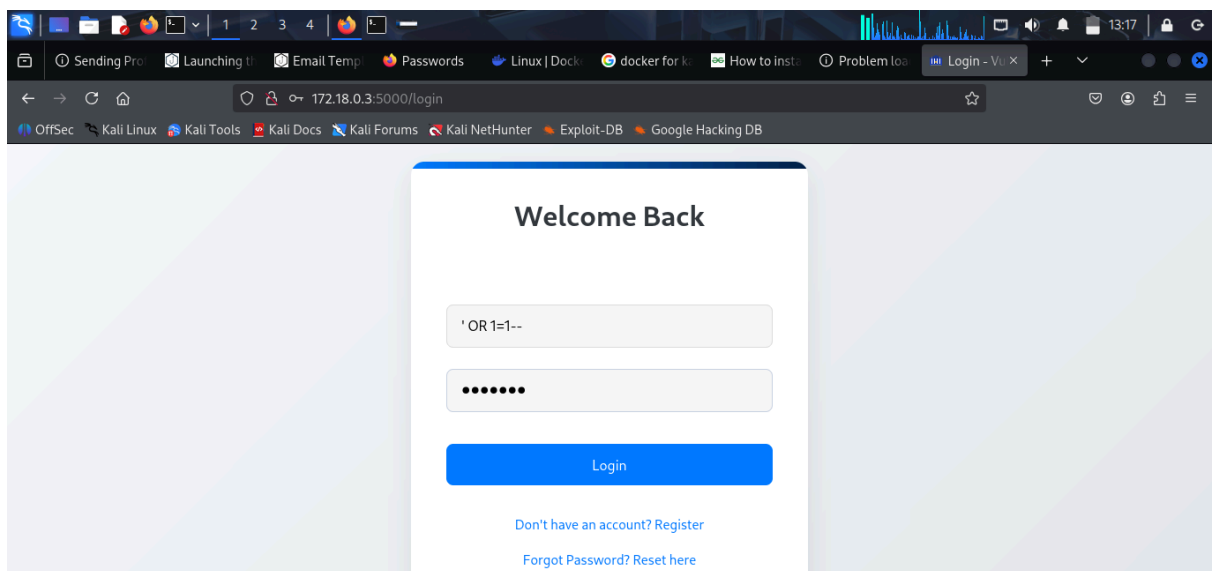
Source: vuln-bank (<https://github.com/Commando-X/vuln-bank>)

Vulnerability 1: No Rate Limit on Password Attempts

A user has unlimited attempts to give the password. An attacker can use this vulnerability to brute force the app.

Vulnerability 2: SQL Injection in Login Page

The app is susceptible to SQL injection as by writing ' OR 1=1-- in the username field and entering any password, it gives unauthorized access to the admin profile.



Vulnerability 3: OTP Brute Force

An attacker can brute force the OTP as it has an unlimited number of attempts available. Since it is a 3-digit OTP makes it highly vulnerable as there are only a possible 1000 combinations of OTPs generated.

Vulnerability 4: Negative Amount Transfer

The image displays two screenshots of a web application interface. The top screenshot shows the 'User Management' section, which contains a table of users. The bottom screenshot shows the 'Money Transfer' section, where a negative amount of -1000 is entered for a transfer to account 8340552490.

User Management

ID	Username	Account Number	Balance	Admin	Actions
2	Merlin	2139982692	\$1000.00	True	Delete
1	admin	ADMIN001	\$978710.00	True	Delete
4	artemis	8340552490	\$21000.00	True	Delete

Create Admin Account

Vulnerable Bank

- Profile
- Money Transfer**
- Loans
- Transaction History
- Virtual Cards
- Bill Payments

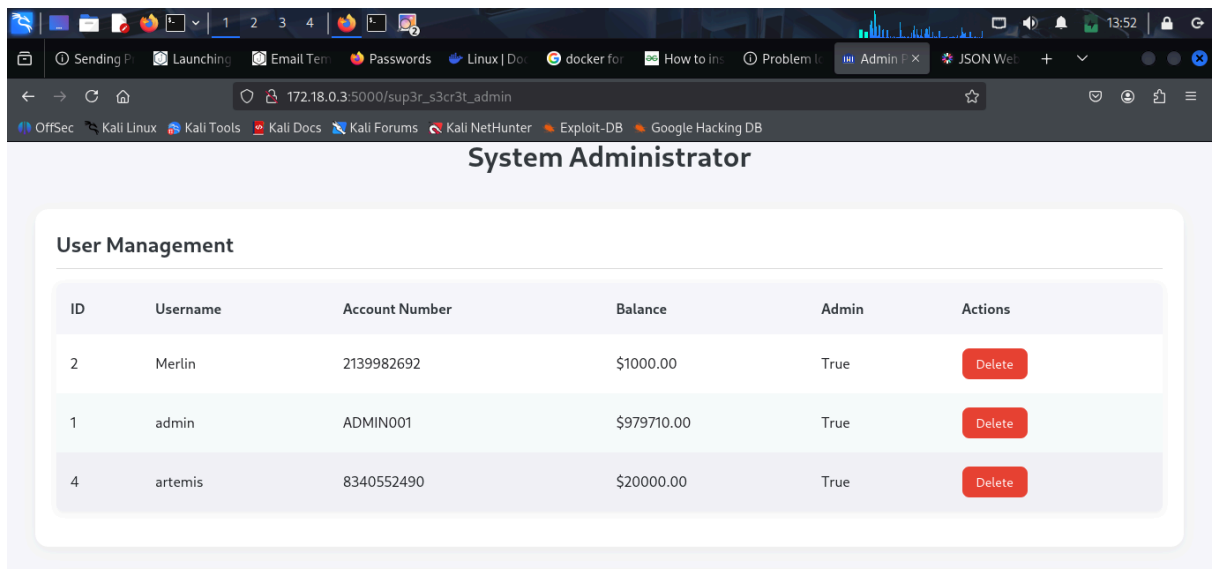
Money Transfer

Recipient Account Number: 8340552490

Amount: -1000

Description (optional): Add a note about this transfer

Send Money



Vulnerability 5: Insufficient Authorization

Anyone can create an admin account and the admin account has the ability to modify an user's account balance. This can lead to financial frauds.

